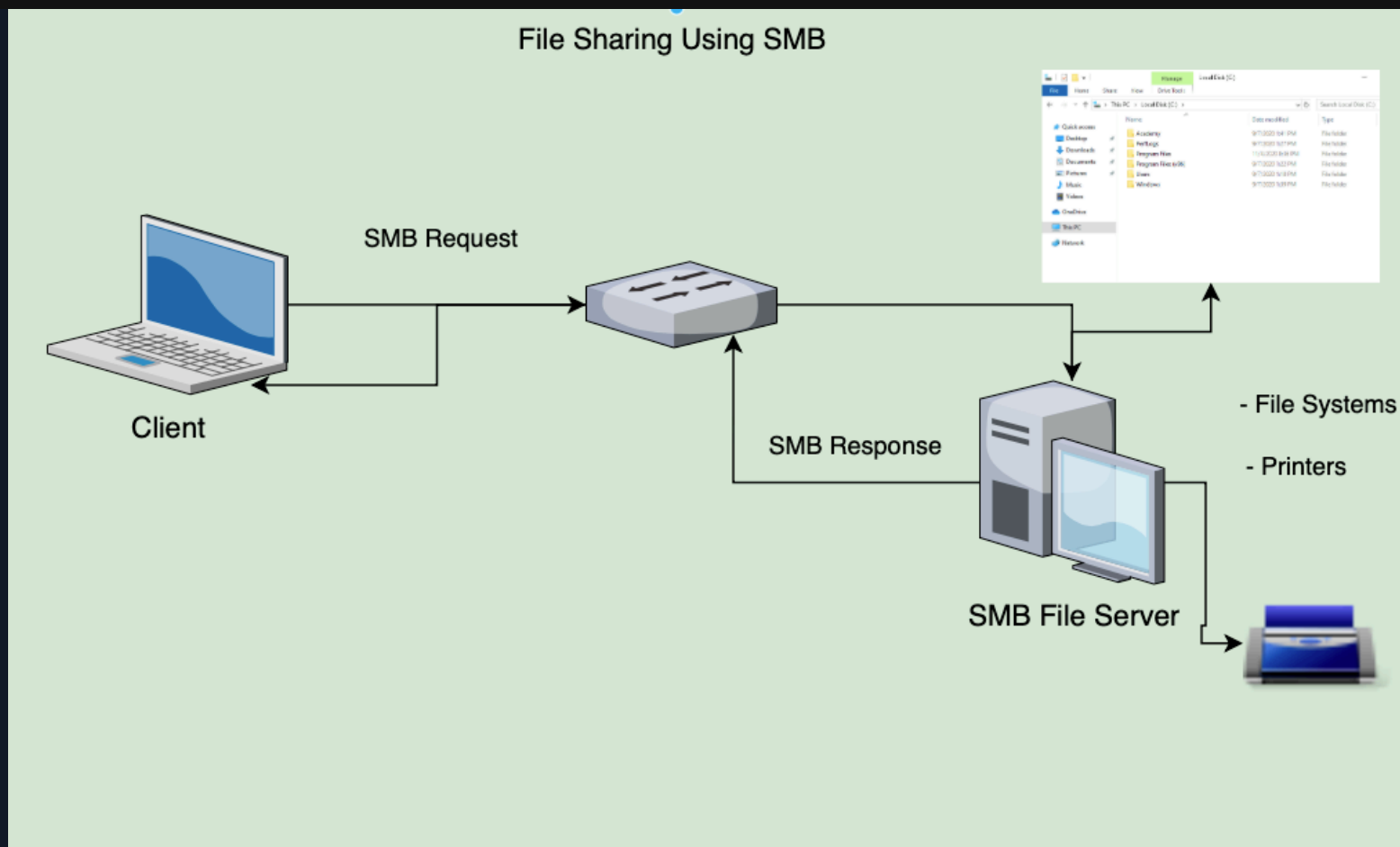




NTFS vs. Share Permissions

Microsoft owns over **70%** of the global market share on desktop operating systems with Windows. This explains why most malware authors choose to write malware for Windows and why many perceive Windows as less secure than other operating systems. From a business perspective it just makes sense for malware authors to expend resources on writing malware for Windows. It is a high-value target. The idea that any OS is immune to malware is a technical fallacy. If software can be written for an operating system then a virus can be written for an operating system. Keep in mind that a virus, by definition, is software written with malicious intent and can be written for any OS. Many variants of malware written for Windows can spread over the network via network shares with lenient permissions applied. It is also worth noting that to this day, the infamous **EternalBlue** vulnerability still haunts unpatched Windows systems running **SMBv1** and often paves the way for ransomware to shut down organizations.

The **Server Message Block protocol (SMB)** is used in Windows to connect shared resources like files and printers. It is used in large, medium, and small enterprise environments. See the image below to visualize this concept:



Note: Any time you see a visualization/diagram of a concept, take your time to understand it thoroughly. A picture can be worth a thousand words but very tempting to skip over when reading.

NTFS permissions and share permissions are often understood to be the same. Please know that they are not the same but often apply to the same shared resource. Let's take a look at the individual permissions that can be set to secure/grant objects access to a network share hosted on a Windows OS running the NTFS file system.

Share permissions

Permission	Description
Full Control	Users are permitted to perform all actions given by Change and Read permissions as well as change permissions for NTFS files and subfolders
Change	Users are permitted to read, edit, delete and add files and subfolders
Read	Users are allowed to view file & subfolder contents

NTFS Basic permissions

Permission	Description
Full Control	Users are permitted to add, edit, move, delete files & folders as well as change NTFS permissions that apply to all allowed folders
Modify	Users are permitted or denied permissions to view and modify files and folders. This includes adding or deleting files
Read & Execute	Users are permitted or denied permissions to read the contents of files and execute programs
List folder contents	Users are permitted or denied permissions to view a listing of files and subfolders
Read	Users are permitted or denied permissions to read the contents of files

Permission	Description
Write	Users are permitted or denied permissions to write changes to a file and add new files to a folder
Special Permissions	A variety of advanced permissions options

NTFS special permissions

Permission	Description
Full control	Users are permitted or denied permissions to add, edit, move, delete files & folders as well as change NTFS permissions that apply to all permitted folders
Traverse folder / execute file	Users are permitted or denied permissions to access a subfolder within a directory structure even if the user is denied access to contents at the parent folder level. Users may also be permitted or denied permissions to execute programs
List folder/read data	Users are permitted or denied permissions to view files and folders contained in the parent folder. Users can also be permitted to open and view files
Read attributes	Users are permitted or denied permissions to view basic attributes of a file or folder. Examples of basic attributes: system, archive, read-only, and hidden

Permission	Description
Read extended attributes	Users are permitted or denied permissions to view extended attributes of a file or folder. Attributes differ depending on the program
Create files/write data	Users are permitted or denied permissions to create files within a folder and make changes to a file
Create folders/append data	Users are permitted or denied permissions to create subfolders within a folder. Data can be added to files but pre-existing content cannot be overwritten
Write attributes	Users are permitted or denied to change file attributes. This permission does not grant access to creating files or folders
Write extended attributes	Users are permitted or denied permissions to change extended attributes on a file or folder. Attributes differ depending on the program
Delete subfolders and files	Users are permitted or denied permissions to delete subfolders and files. Parent folders will not be deleted
Delete	Users are permitted or denied permissions to delete parent folders, subfolders and files.
Read permissions	Users are permitted or denied permissions to read permissions of a folder
Change permissions	Users are permitted or denied permissions to change permissions of a file or folder

Permission	Description
Take ownership	Users are permitted or denied permission to take ownership of a file or folder. The owner of a file has full permissions to change any permissions

Keep in mind that NTFS permissions apply to the system where the folder and files are hosted. Folders created in NTFS inherit permissions from parent folders by default. It is possible to disable inheritance to set custom permissions on parent and subfolders, as we will do later in this module. The share permissions apply when the folder is being accessed through SMB, typically from a different system over the network. This means someone logged in locally to the machine or via RDP can access the shared folder and files by simply navigating to the location on the file system and only need to consider NTFS permissions. The permissions at the NTFS level provide administrators much more granular control over what users can do within a folder or file.

Creating a Network Share

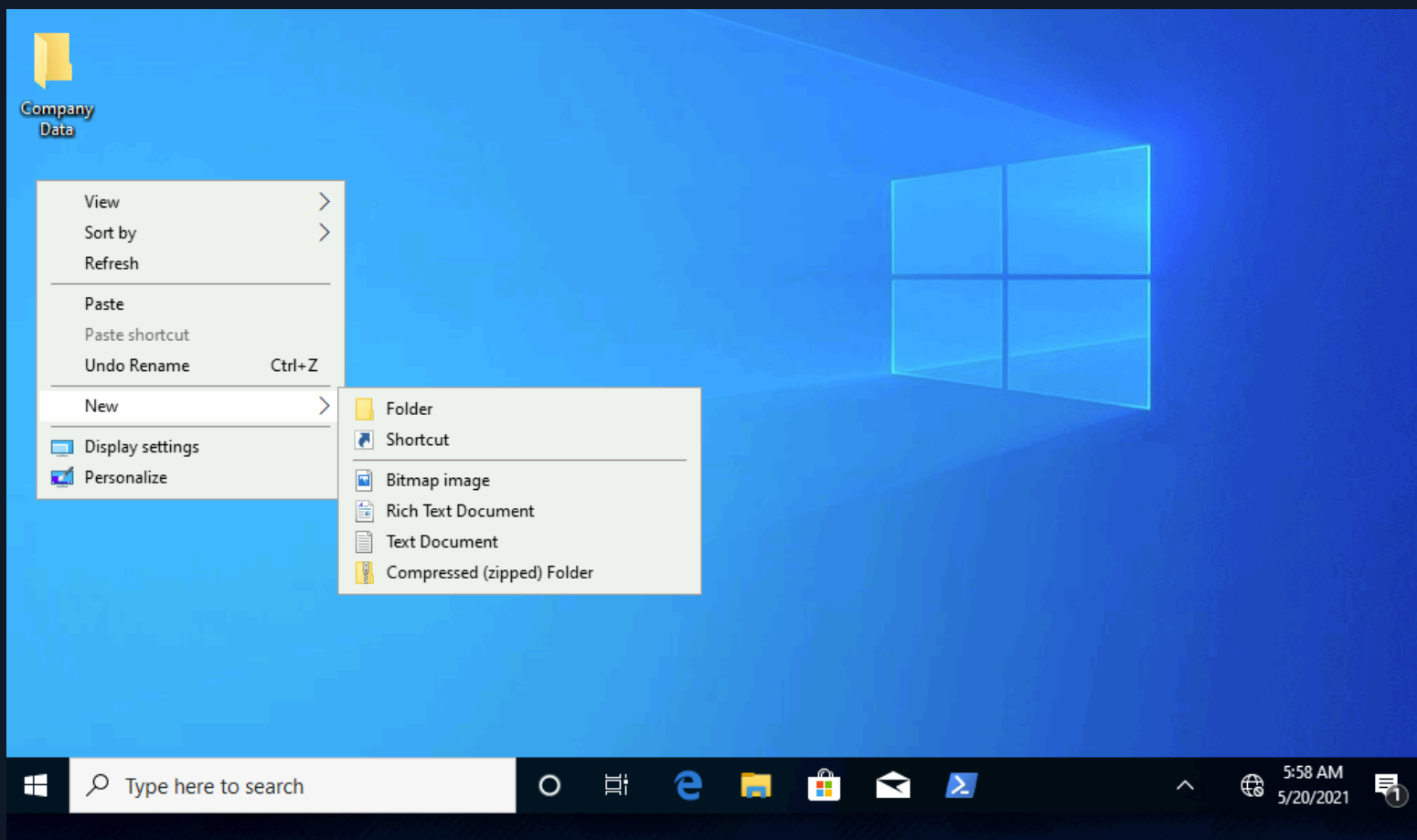
To get a solid fundamental understanding of SMB and it's relationship to NTFS, we will create a network share on the `Windows 10 target box`.

Note: It is an ideal learning experience to have the Pwnbox open full screen on a separate monitor so we may have at least one display dedicated to displaying the written content and one display for the boxes we are interacting with. Alternatively, if we only have access to one display, we can use that one for interactions with boxes and a smartphone or tablet to reference the written content.

In this case, we will create a shared folder by first creating a new folder on the Windows 10 desktop. Keep in mind that in most large enterprise environments, shares are created on a Storage Area Network (SAN), Network Attached Storage device (NAS), or a separate partition on drives accessed via a server operating system like Windows Server. If we ever come across shares on a desktop operating system, it will either be a small business or it could be a beachhead system used by a penetration tester or malicious attacker to gather and exfiltrate data.

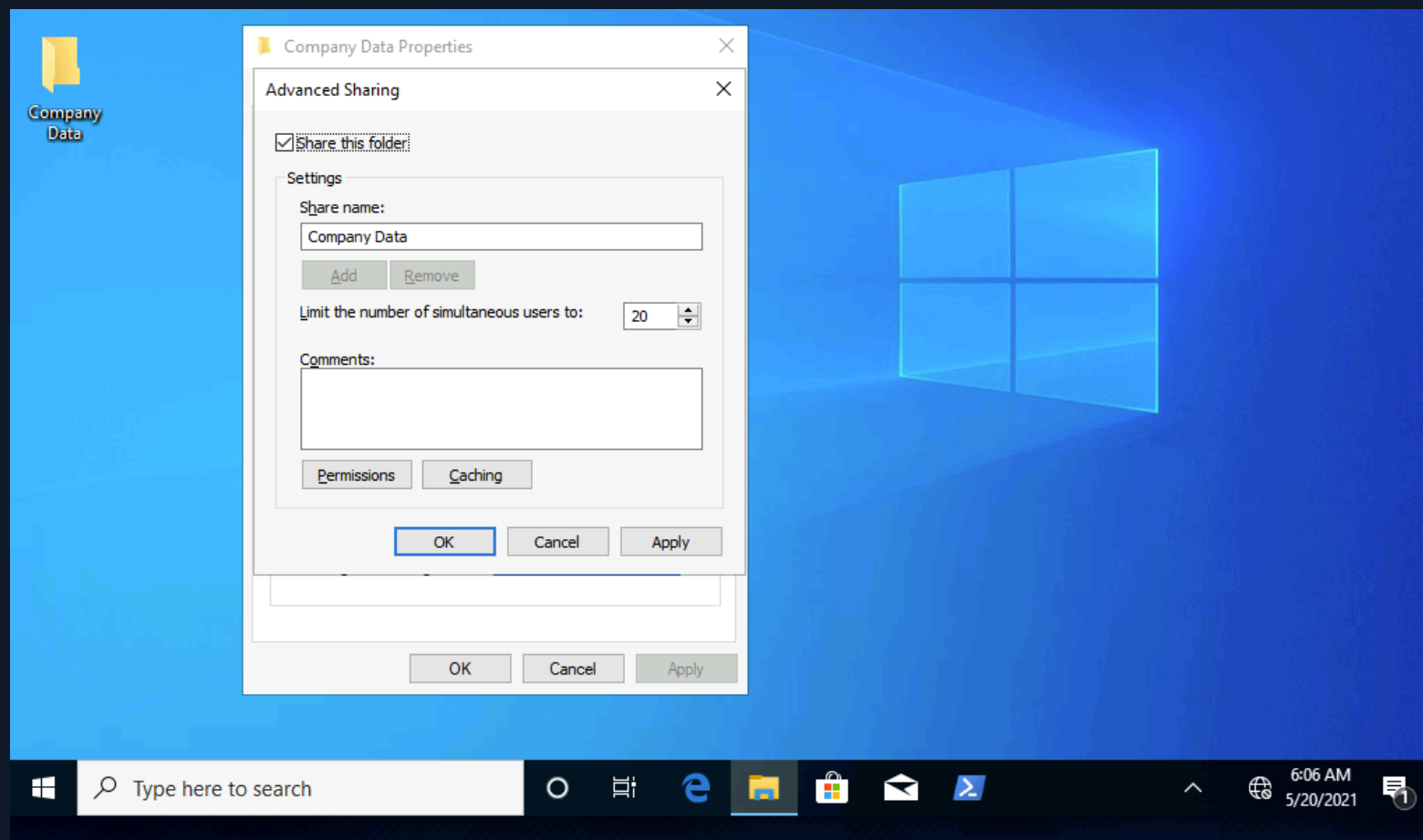
We will go through this process using the GUI in Windows.

Creating the Folder



We are going to use the **Advanced Sharing** option to configure our share.

Making the Folder a Share

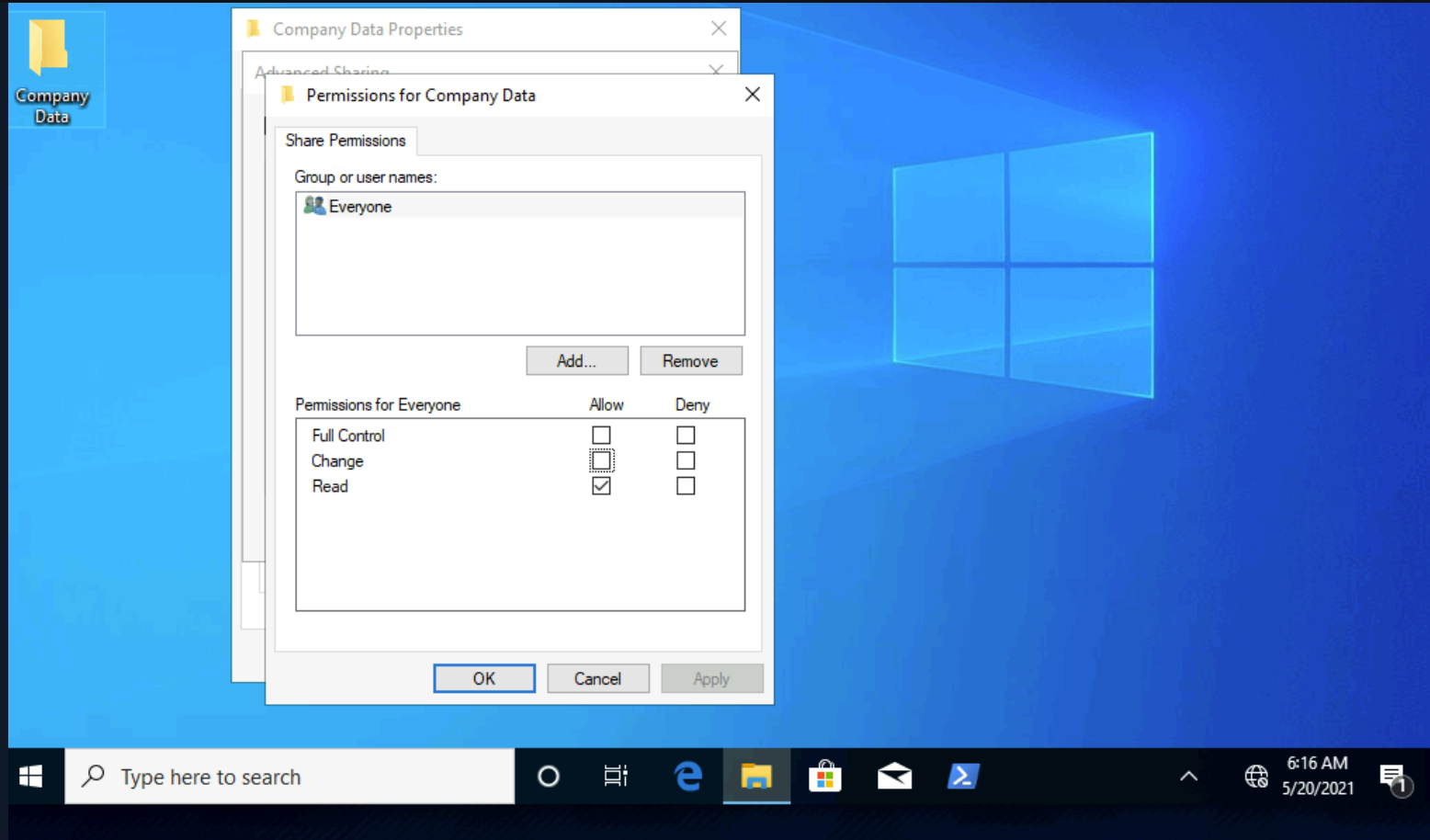


Notice how the share name automatically defaults to the name of the folder. Also, we can see that it is possible to limit the number of users that can be connected to this share simultaneously. In a real-world environment it is a good practice for administrators to set this number according to the number of users that regularly need access to the resource being shared.

Similar to NTFS permissions, there is an `access control list` (`ACL`) for shared resources. We can consider this the SMB permissions list. Keep in mind that with shared resources, both the SMB and NTFS permissions lists apply to every resource that gets shared in Windows. The ACL contains `access control entries` (`ACEs`). Typically these ACEs are made up of `users` & `groups` (also called security principals) as they are a suitable mechanism for managing and tracking access to shared resources.

Notice the default access control entry and permissions settings.

Share Permissions ACL (Sharing Tab)



For now, we are going to apply these settings to test the effect of this ACL and the permissions applied as-is. We will test connectivity from the Pwnbox by opening terminal and using `smbclient`.

Note: A server is technically a software function used to service the requests of a client. In this case, the Pwnbox is our client, and the Windows 10 target box is our server.

Using smbclient to list available shares

```
athane@htb[/htb]$ smbclient -L SERVER_IP -U htb-student
Enter WORKGROUP\htb-student's password:
```

Sharename	Type	Comment
-----	----	-----
ADMIN\$	Disk	Remote Admin
C\$	Disk	Default share
Company Data	Disk	
IPC\$	IPC	Remote IPC

Connecting to the Company Data share

```
athane@htb[/htb]$ smbclient '\\SERVER_IP\Company Data' -U htb-student
Password for [WORKGROUP\htb-student]:
Try "help" to get a list of possible commands.

smb: \>
```

shellsession

What could potentially block us from accessing this share if all our entries are correct and our permissions list has the Everyone group present with at least Read permissions?

Windows Defender Firewall Considerations

It is the Windows Defender Firewall that could potentially be blocking access to the SMB share. Since we are connecting from a Linux-based system the firewall has blocked access from any device that is not joined to the same **workgroup**. It is also important to note that when a

Windows system is part of a workgroup, all **netlogon** requests are authenticated against that particular Windows system's **SAM** database. When a Windows system is joined to a Windows Domain environment, all netlogon requests are authenticated against **Active Directory**. The primary difference between a workgroup and a Windows Domain in terms of authentication, is with a workgroup the local SAM database is used and in a Windows Domain a centralized network-based database (Active Directory) is used. We must know this information when attempting to logon & authenticate with a Windows system. Consider where the htb-student account is hosted to properly connect to the target.

In terms of the firewall blocking connections, this can be tested by completely deactivating each firewall profile in Windows or by enabling specific predefined inbound firewall rules in the **Windows Defender Firewall advanced security settings**. Like most firewalls, Windows Defender Firewall permits or denies traffic (access & connection requests in this case) flowing **inbound** &/or **outbound**

The different inbound and outbound rules are associated with the different firewall profiles in defender.

Windows Defender Firewall Profiles:

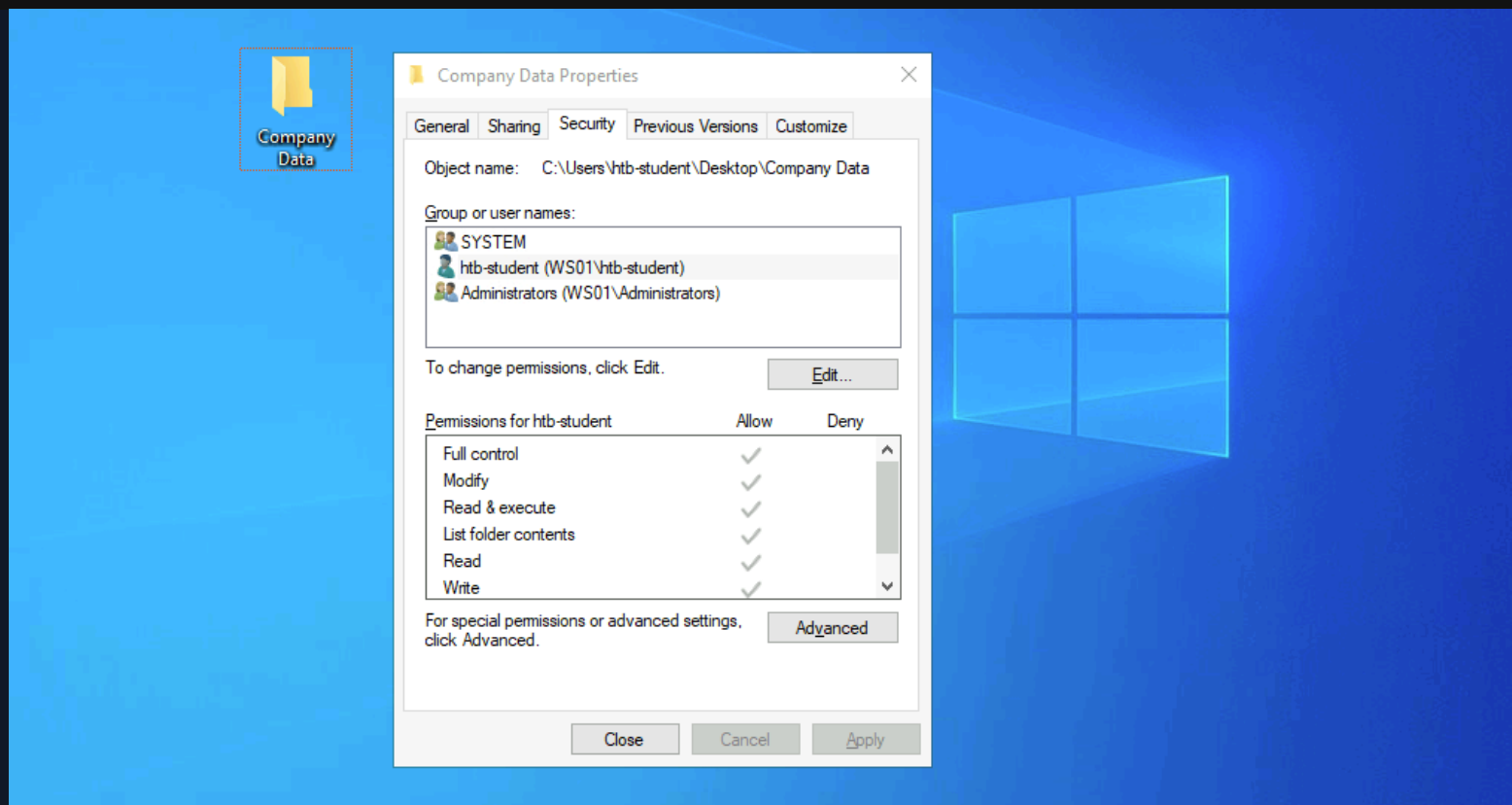
- **Public**
- **Private**
- **Domain**

It is a best practice to enable predefined rules or add custom exceptions rather than deactivating the firewall altogether. Unfortunately, it is very common for firewalls to be left completely

deactivated for the sake of convenience or lack of understanding. Firewall rules on desktop systems can be centrally managed when joined to a Windows Domain environment through the use of Group Policy. Group Policy concepts and configurations are outside of the scope of this module.

Once the proper `inbound` firewall rules are enabled we will successfully connect to the share. Keep in mind that we can only connect to the share because the user account we are using (`htb-student`) is in the `Everyone group` . Recall that we left the specific share permissions for the Everyone group set to Read, which quite literally means we will only be able to Read files on this share. Once a connection is established with a share, we can create a `mount point` from our Pwnbox to the Windows 10 target box's file system. This is where we must also consider that NTFS permissions apply alongside share permissions. Recall that NTFS is the default file system in Windows. Lets jump back to our xfreerdp session with our Windows 10 target box and take a look at the NTFS permissions on the Company Data folder.

NTFS Permissions ACL (Security Tab)



There's more granular control with NTFS permissions that can be applied to users and groups. Anytime we see a gray checkmark next to a permission, it was inherited from a parent directory. By default, all NTFS permissions are inherited from the parent directory. In the Windows world, the `C:\ drive` is the parent directory to rule all directories unless a system administrator were to disable inheritance inside a newly created folder's advanced Security settings.

In many cases, the system administrator(s) of an organization would be responsible for deciding what permissions a user or group of users gets over network resources. This is why many spear-phishing attacks are directed at system administrators and other IT leaders. They have lots of influence over what is allowed in the environments they oversee, even more so than an

organization's non-technical c-level leaders in many cases. For example, the doctors or executives working in a hospital will not have administrative rights over the network, but the system administrators will.

Now lets give the Everyone group **Full control** at the share level and test the impact of the change by trying to create a mount point to the share from the Desktop of our Pwnbox

Mounting to the Share

```
shellsession  
athane@htb[/htb]$ sudo mount -t cifs -o username=htb-student,password=Academy_WinFun!  
//ipaddoftarget/"Company Data" /home/user/Desktop/
```

If this command is not working check the syntax. If the syntax is correct yet the command is still not working, **cifs-utils** may need to be installed. This can be done with the following command:

Installing CIFS Utilities

```
shellsession  
athane@htb[/htb]$ sudo apt-get install cifs-utils
```

Once we have successfully created the mount point on the Desktop on our Pwnbox, we should look at a couple of tools built-in to Windows that will allow us to track and monitor what we have done.

The `net share` command allows us to view all the shared folders on the system. Notice the share we created and also the C:\ drive.

Do you remember us sharing the C:\ drive?

We didn't manually share C:. The most important drive with the most critical files on a Windows system is shared via SMB at install. This means anyone with the proper access could remotely access the entire C:\ of each Windows system on a network.

We can also see the share we created.

Displaying Shares using net share

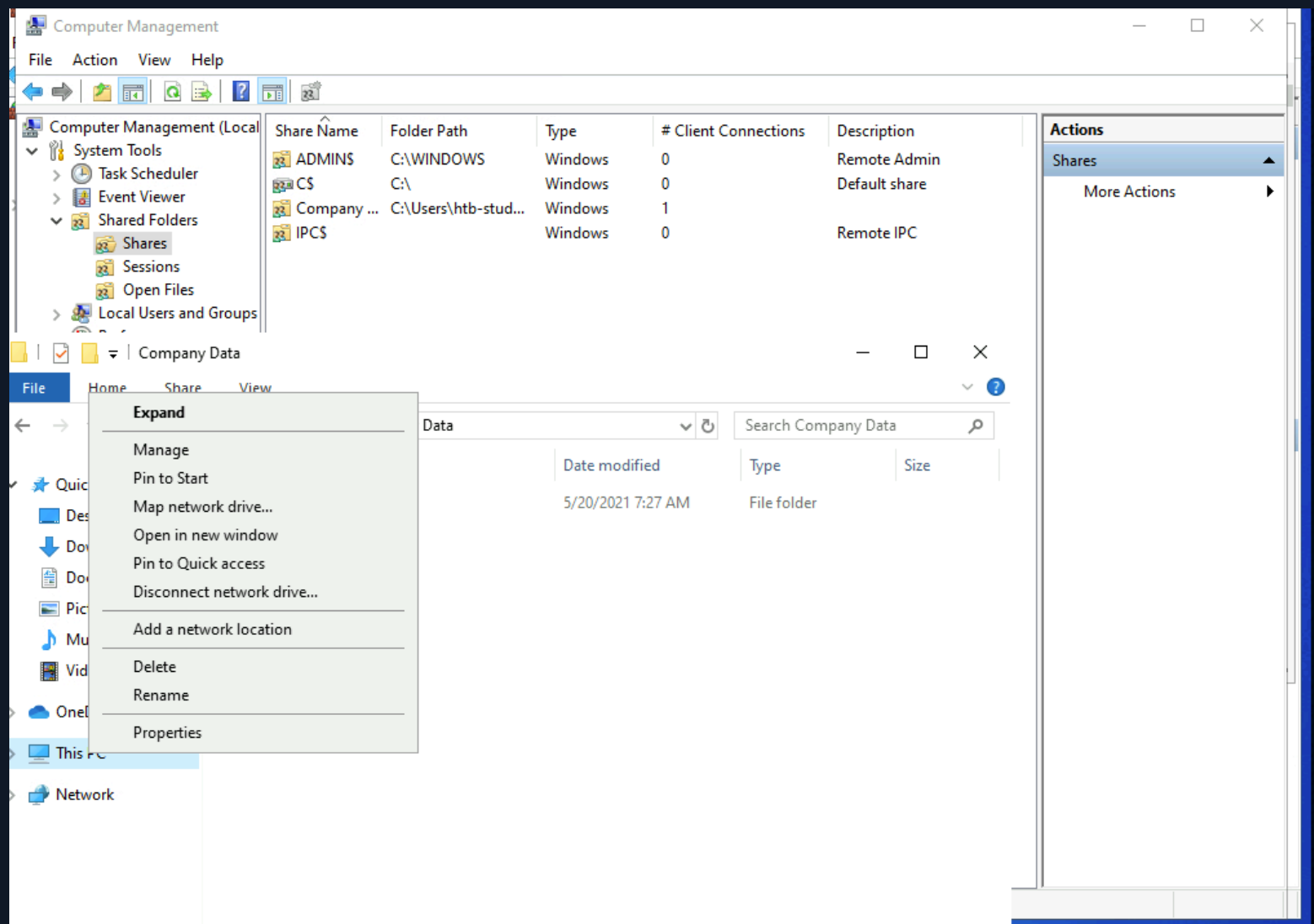
```
C:\Users\htb-student> net share
```

Share name	Resource	Remark
C\$	C:\	Default share
IPC\$		Remote IPC
ADMIN\$	C:\WINDOWS	Remote Admin
Company Data	C:\Users\htb-student\Desktop\Company Data	

The command completed successfully.

`Computer Management` is another tool we can use to identify and monitor shared resources on a Windows system.

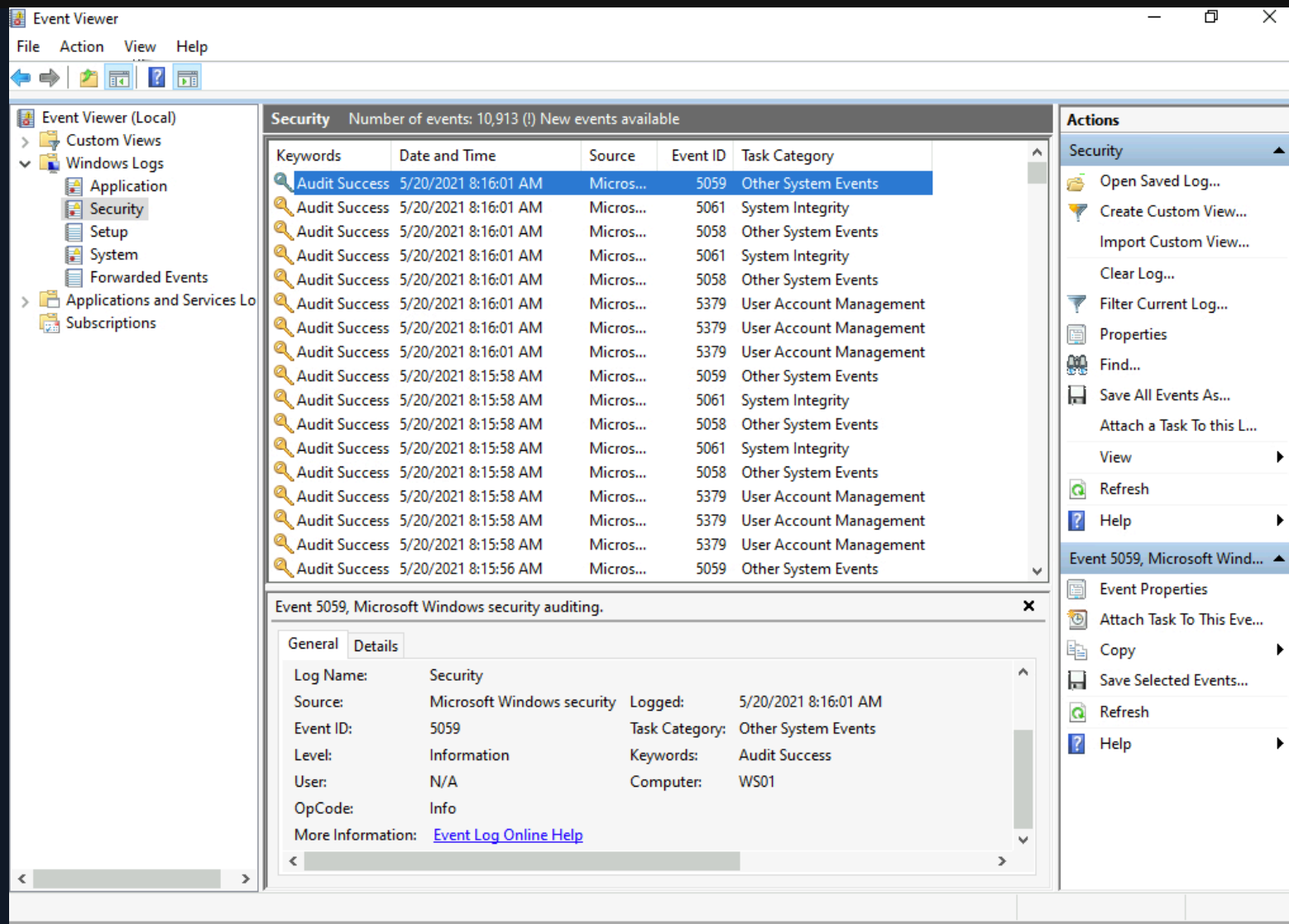
Monitoring Shares from Computer Management



We can poke around in **Shares**, **Sessions**, and **Open Files** to get an idea of what information this provides us. Should there be a situation where we assist an individual or organization with responding to a breach related to SMB, these are some great places to check and start to understand how the breach may have happened and what may have been left behind.

Viewing Share access logs in Event Viewer

Event Viewer is another good place to investigate actions completed on Windows. Almost every operating system has a logging mechanism and a utility to view the logs that were captured. Know that a log is like a journal entry for a computer, where the computer writes down all the actions that were performed and numerous details associated with that action. We can view the logs created for every action we performed when accessing the Windows 10 target box, as well as when creating, editing and accessing the shared folder.



Connect to HTB

Target(s)

Time left: 94 min(s)

 **10.129.201.57** (ACADEMY-MISC-WS01)

Enable step-by-step solutions ⓘ

PRO

Question 1



What protocol discussed in this section is used to share resources on the network using Windows? (Format: case sensitive)

RDP to **10.129.201.57 (ACADEMY-MISC-WS01)**, with user "**htb-student**" and password "**Academy_WinFun!**"

Write your answer

 Submit Hint

Question 2



What is the name of the utility that can be used to view logs made by a Windows system? (Format: 2 words, 1 space, not case sensitive)

Write your answer

 Submit

 Hint

Question 3

 +1

 +20



What is the full directory path to the Company Data share we created?

Write your answer

 Submit

 Hint



4 / 14 Sections



Mark Complete & Next